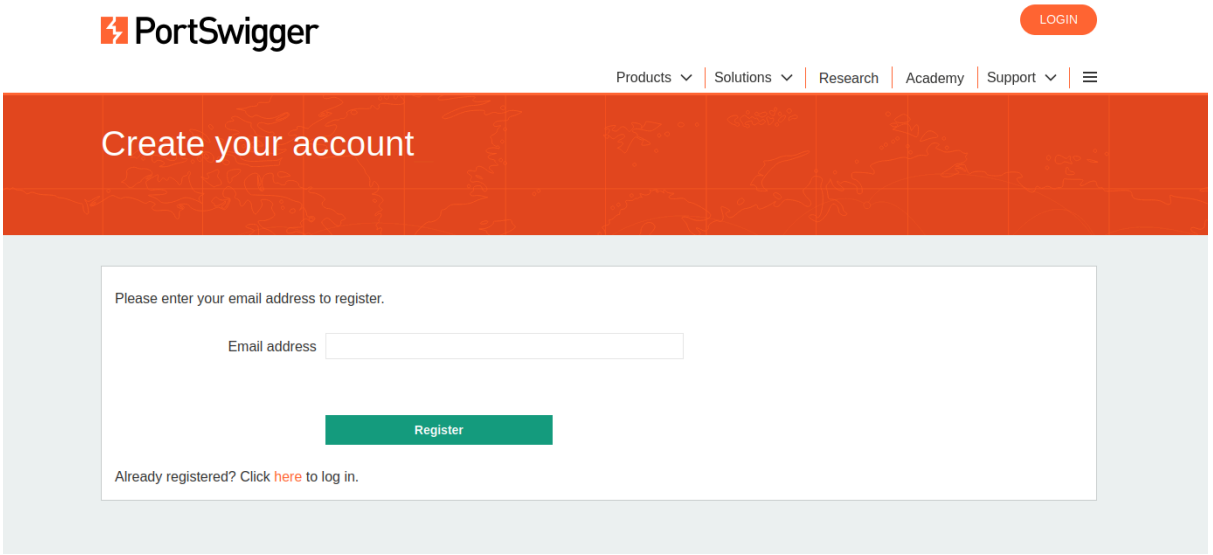
CYBER CHAP 1.2 :
UTILISATION D'UN LOGICIEL DE PENTEST POUR TESTER LES AUTHENTIFICATIONS SIMPLES

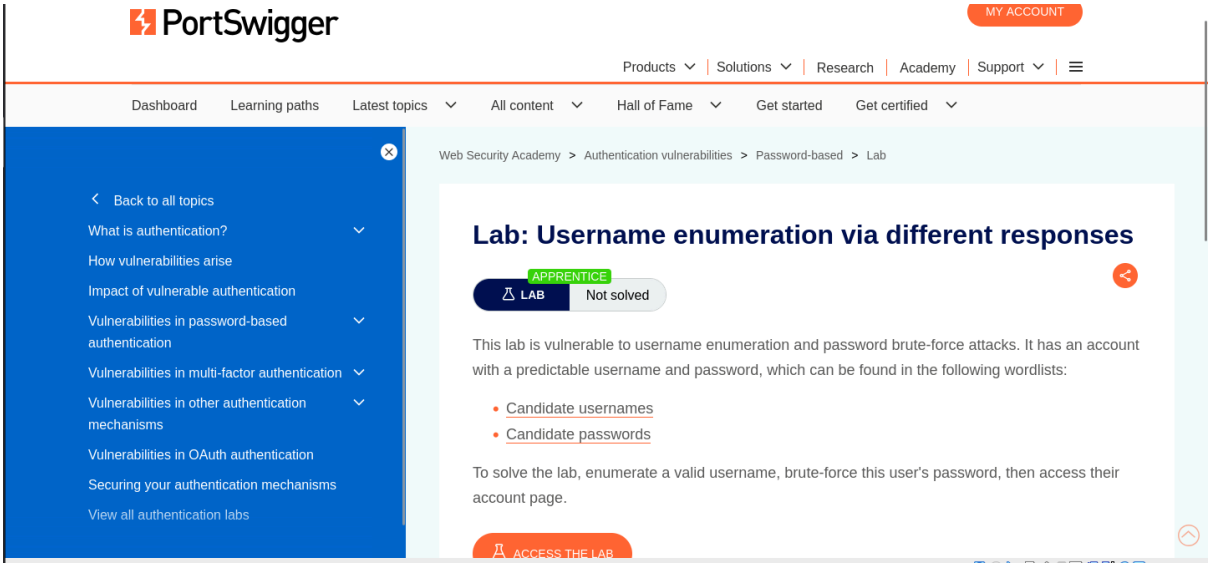
I – PRÉPARATION DU FICHIER

Pour commencer on va créer un compte PortSwinger et se connecter pour pouvoir utiliser Burp Suit.

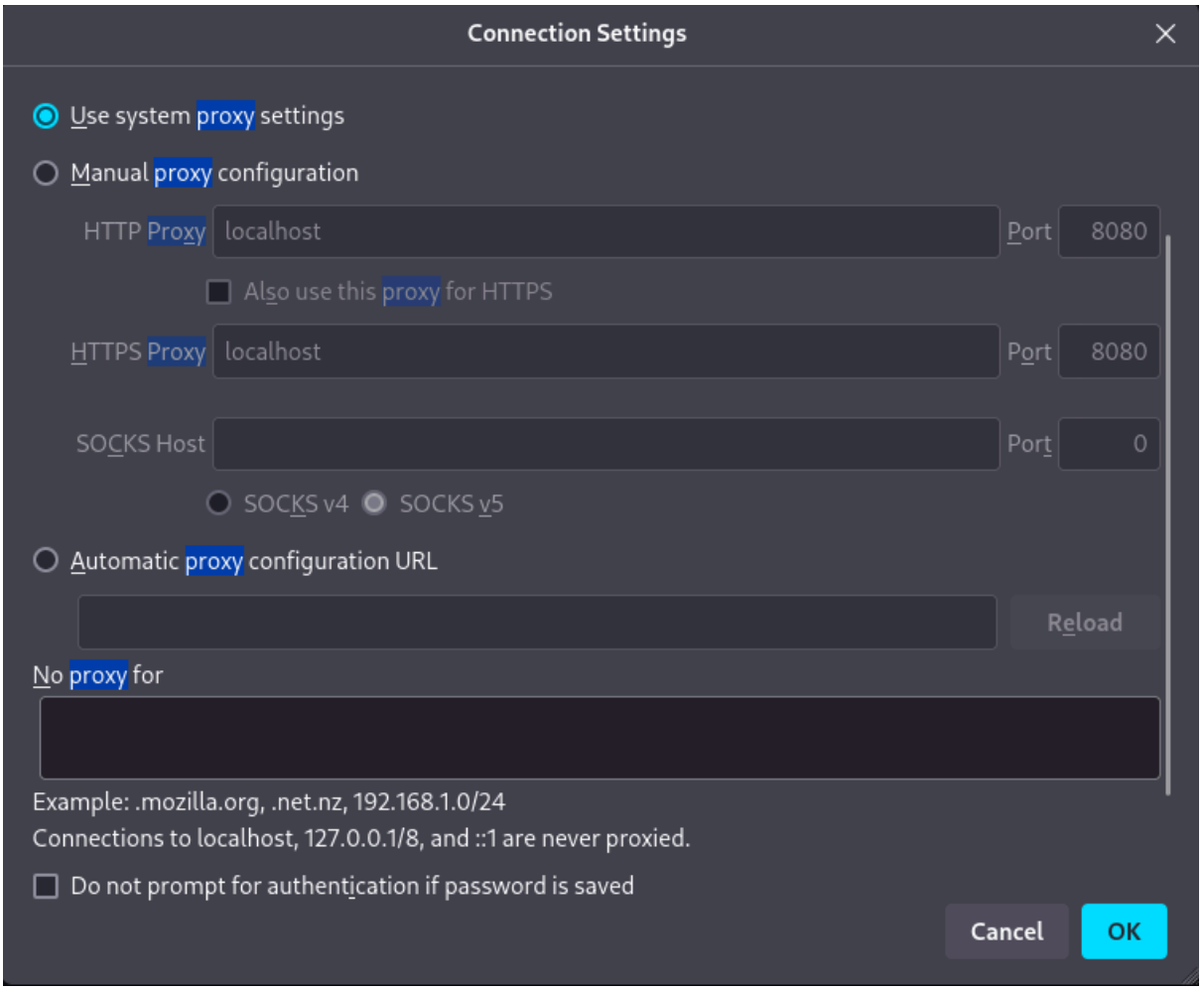


1:

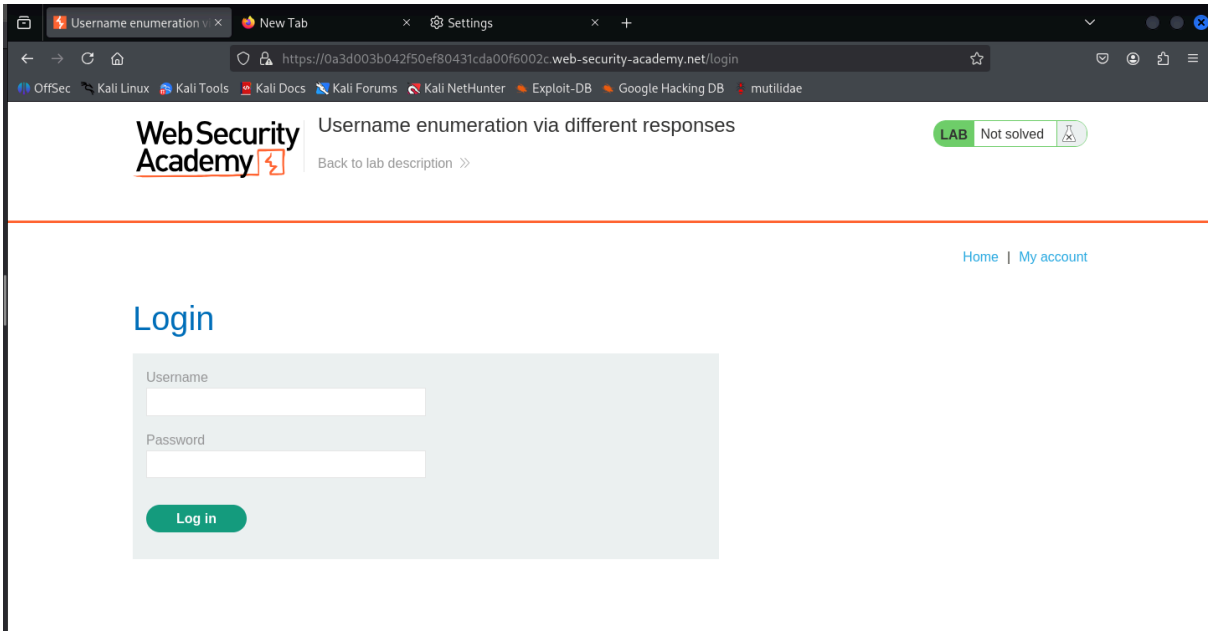
Il faut accéder au Lab maintenant.



Par suite, sur firefox on active le proxy

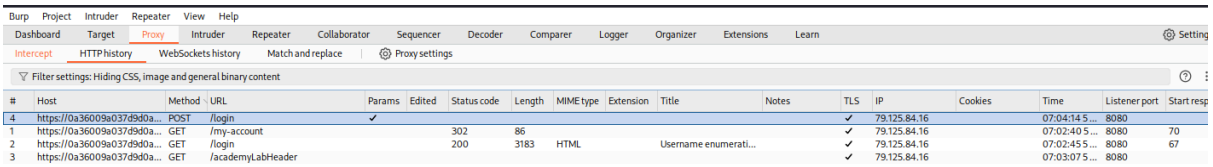


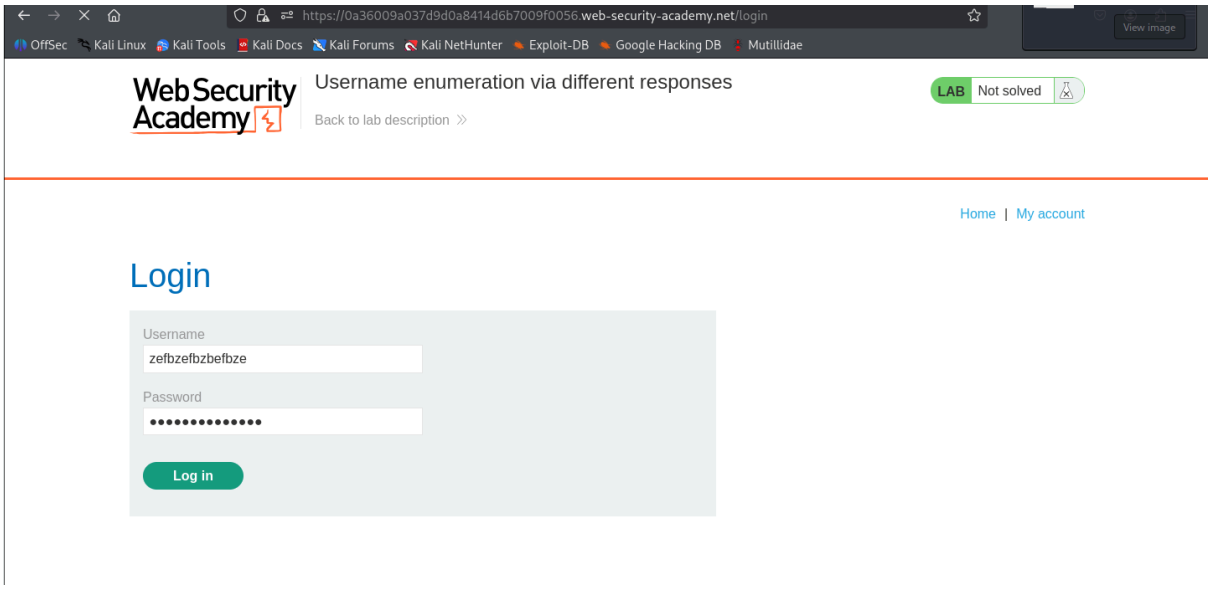
Pour accéder à cette page, on clique sur “My account”.



2:

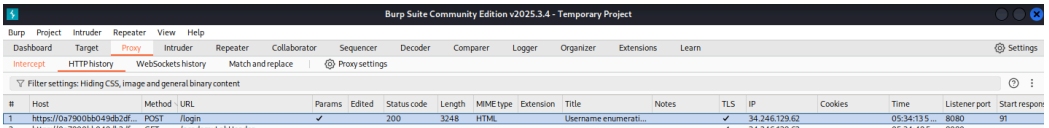
Cliquez sur “Intercept On”

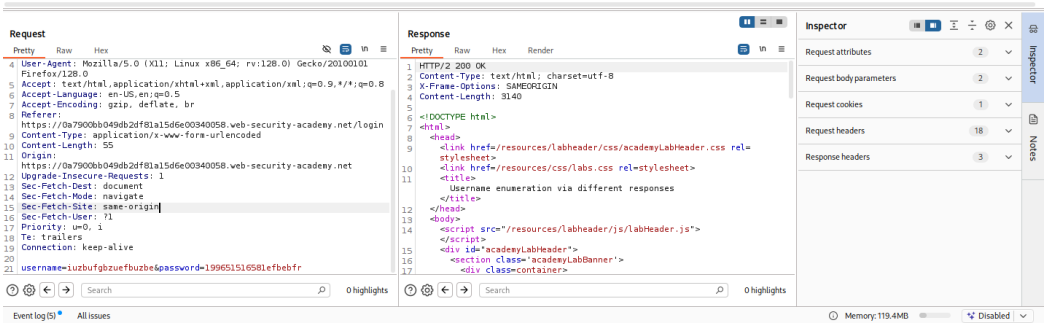




3:

Après avoir cliqué sur “Forward” on ouvre l’onglet HTTP history et filtre les requêtes par “POST”, jusqu'à trouver “POST/login”.





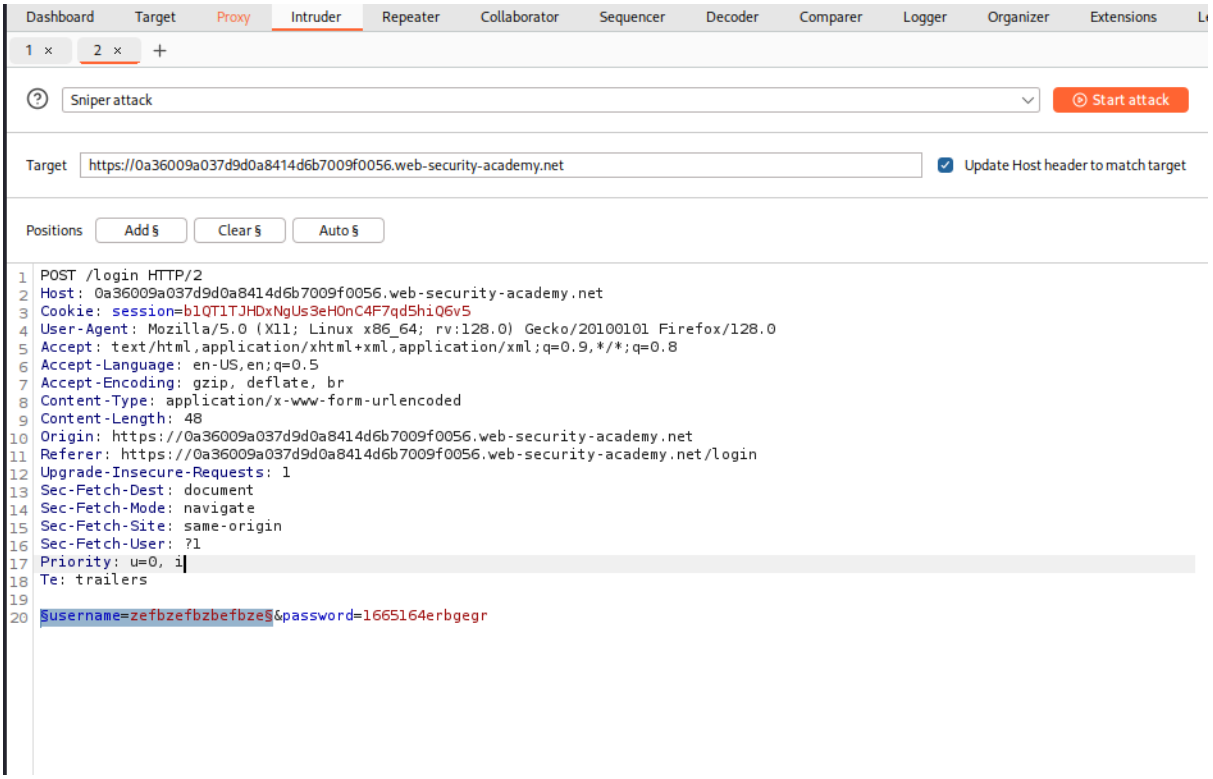
4:

Dans la partie “Request” on observe le username et le password que on a entré lors de la connexion. Par la suite on envoie le username au “Intruder” en faisant un clic droit et en cliquant sur “Send to Intruder”.

```
18 Te: trailers
19
20 username=zefbzefbzbefbze&password=1665164erbgegr
```

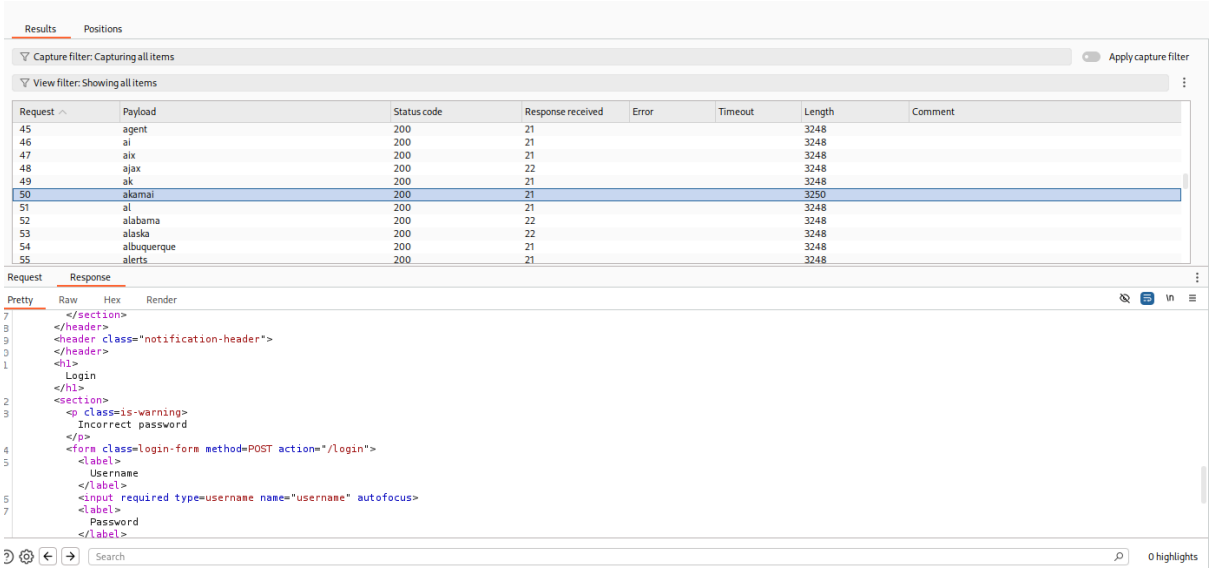
5:

Voici la réponse dans le Intruder.



6:

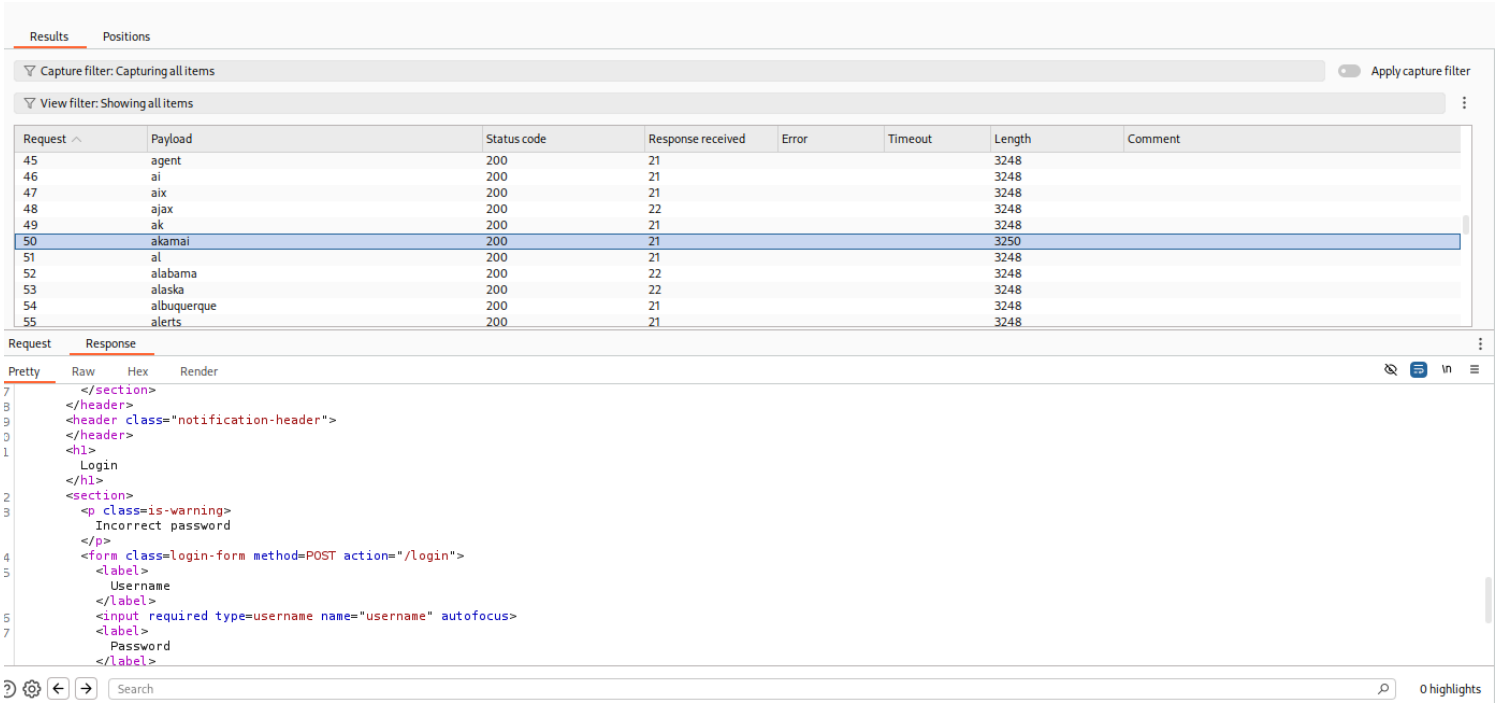
Après avoir chargé la liste de users on click sur “start attack” est on arrive sur cet onglet.



7:

On voit que la requête n°88 fait une longueur de 3250 comparé aux autres qui font 3248 de longueurs.

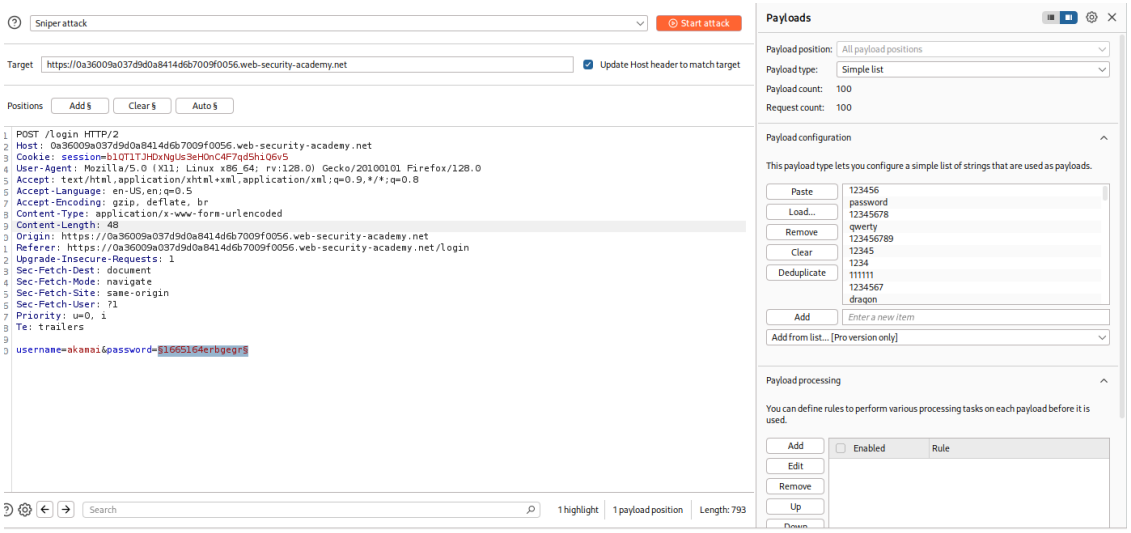
On voit à la ligne 53 que c’est écrit “Incorrect password”.



2) FORCE BRUTE DU MOT DE PASSE DU LOGIN VALIDE

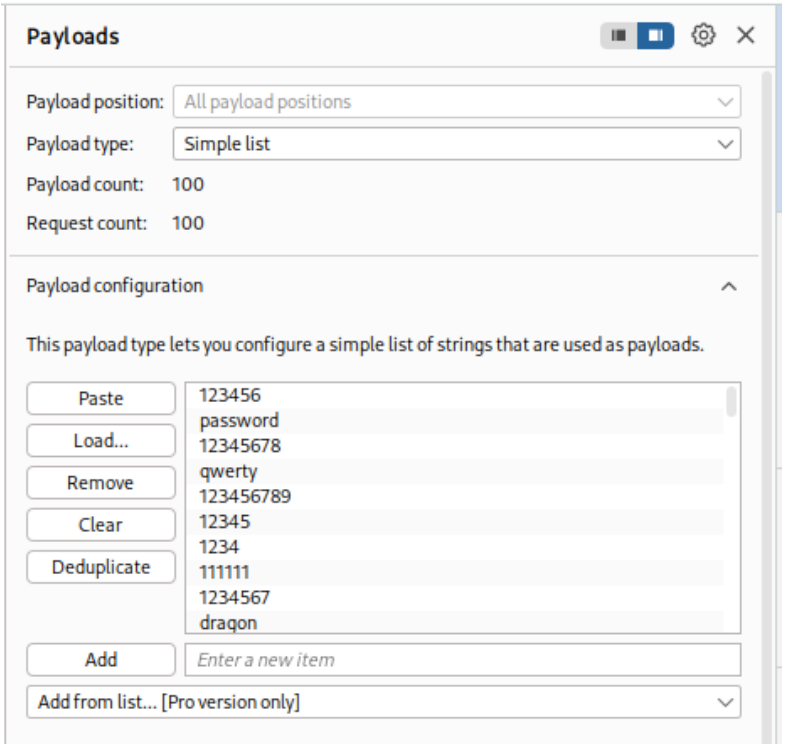
1:

Maintenant pour trouver le mot de passe ont fait la même chose que pour le username, ont met deux signe “§“entre le mot de passe incorrecte saisi, et ont lance ensuite l’attaque en cliquant sur “start attack”.



2:

Dans l’onglet payload on charge la liste des mot de passe fournis.



3:

On obtient une réponse 302 ce qui signifie que le mot de passe trouvé est correct.

Request Response

Pretty Raw Hex Render

```
1 HTTP/2 302 Found
2 Location: /my-account?id=akamai
3 Set-Cookie: session=FZK9cSyoGRB9y3mQgKaiQD8mkN475Zq7; Secure; HttpOnly; SameSite=None
4 X-Frame-Options: SAMEORIGIN
5 Content-Length: 0
6
```

4:

Après avoir entré le mot de passe et le nom d'utilisateur ont peut observer que sa a bien marché.

Web Security Academy | Username enumeration via different responses | LAB Solved

Back to lab description

Congratulations, you solved the lab! Share your skills! Continue learning

Home | My account | Log out

My Account

Your username is: akamai

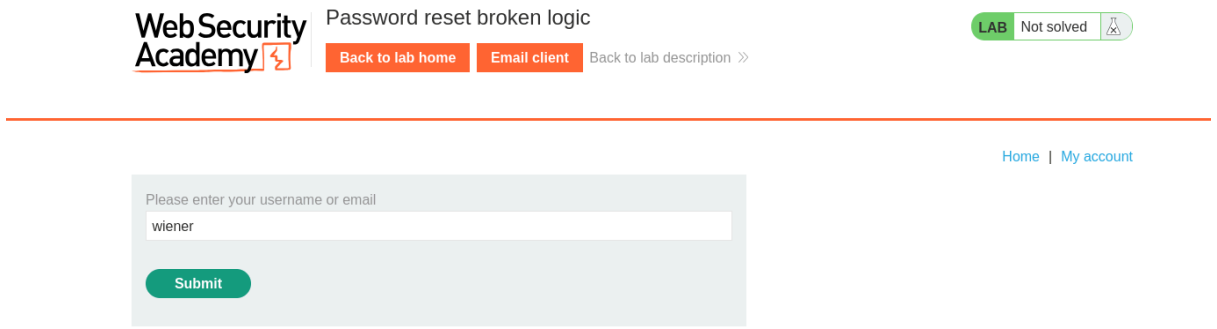
Your email is: akamai@normal-user.net

Email

Update email

II – RÉINITIALISATION MALVEILLANTE D’UN MOT DE PASSE

Sur cette page, il faut cliquer sur forget password et entrer le nom



1: